Week 2 Controls

Readings
The following reading is available on the unit website:

- CIS Controls v8. Please read at least pages 8-19.
    - 1 Inventory and Control of Enterprise Assets
    - 2 Inventory and Control of Software Assets
    - 3 Data Protection
    - 4 Secure Configuration of Enterprise Assets and Software

CIS Controls v8
Where in CIS Controls would you look for the following information?

- What data should I record about a software package that I have just purchased?
- What data should I record about a router I just purchased?
- What data should I record about accesses to sensitive data?
- I need some guidance on how to secure an Apple iPhone.

Compare Control Frameworks
Download the the NIST Controls from
https://doi.org/10.6028/NIST.CSWP.04162018
(https://www.nist.gov/cyberframework/framework-resources).

Compare NIST PR.AT.1 with CIS Safeguard 14.1 Establish and Maintain a Security Awareness Program.

CIS Safeguard 9.2 DNS Filtering

Note: do not use tools such as a webbrowser to investigate potentially malicious domains such as `phishing.testcategory.com`.

Compare the resolution of the domain `phishing.testcategory.com` using Cloudflare's DNS server (1.1.1.3) with Google's (8.8.8.8).

CIS Safeguard 9.5 DMARC
Identify the servers that are permitted to send email on behalf of the domain Microsoft.com.

Google receives 1000 spoofed emails from Microsoft. Where will Google's email servers report this issue?

CIS Safeguard 4.6 Securely Manage Enterprise Assets … – Disable NTP
As another step towards the secure management of your assets, you decide to following a recommendation to disable DC's Network Time Provider (NTP) server. NTP uses UDP port 123.

CRICOS Code: 00219C | RTO Code: 40939
BE WHAT YOU WANT TO BE
cqu.edu.au

First, confirm DC's NTP server is working. The program w32tm can be used to compare your computer's time against another's. Here we check DC's time against its NTP server. Localhost is typically an alias for the IP 127.0.0.1, which is DC.

```
DC PS> w32tm /stripchart /computer:localhost
Tracking localhost [127.0.0.1:123].
The current time is 3/7 2:12:35 PM.
14:15:38, d:+00.0024361s o:-00.0008217s  [       *       ]
```

Disable the NTP server by setting the Enabled property in the registry folder `HKLM:\SYSTEM\CurrentControlSet\Services\w32time\TimeProviders\NtpServer` to 0.

You will also need to restart the W32Time service.

```
PS> restart-service W32Time
```

You should now receive an error:

```
PS> w32tm /stripchart /computer:localhost
Tracking localhost [127.0.0.1:123].
The current time is 3/7/2023 2:19:30 PM.
14:19:30, error: 0x800705B4
```

CIS Safeguard 4.6 Securely Manage Enterprise Assets … – Static Gateway MAC

As another step towards the secure management of your assets, you decide to reduce the risk of ARP cache poisoning by implementing a static MAC address for DC's gateway.

Address Resolution Protocol (ARP) converts an IP address to a Media Access Control (MAC) address so your host can determine which NIC to send an IP packet to. ARP poisoning occurs when a Threat Actor (TA) tells your host that the wrong MAC for an IP.

Take a snapshot of your DC machine and call it "Pre Static ARP" in case something goes wrong.

Obtain the IP address of DC's gateway.

```
DC PS> $gw_IP=(get-netipconfiguration | `
               where InterfaceAlias -eq "Ethernet 4"`
              ).IPv4DefaultGateway.NextHop
PS> echo $gw_IP
10.0.2.2
```

Interpret the State attribute of the ARP cache for DC's gateway.

```
PS> get-netneighbor | where IPAddress -eq $gw_IP
ifIndex IPAddress  LinkLayerAddress  State       PolicyStore
7       10.0.2.2   52-54-00-12-35-02 Reachable   ActiveStore
```

Obtain the MAC address of DC's gateway.

```
PS> $gw_MAC=(get-netneighbor | `
             where IPAddress -eq $gw_IP).LinkLayerAddress
PS> echo $gw_MAC
52-54-00-12-35-02
```

Make the MAC address of DC's gateway static.

```
PS> Remove-NetNeighbor -IPAddress $gw_IP
PS> New-NetNeighbor -IPAddress $gw_IP `
                    -InterfaceAlias "Ethernet 4" `
                    -LinkLayerAddress $gw_MAC `
                    -State Permanent
ifIndex IPAddress  LinkLayerAddress  State     PolicyStore
7       10.0.2.2   52-54-00-12-35-02 Permanent ActiveStore
7       10.0.2.2   52-54-00-12-35-02 Permanent PersistentStore
```

Interpret the State attribute of the ARP cache for DC's gateway again.

Remove the static MAC.

```
PS> Remove-NetNeighbor -IPAddress $gw_IP
PS> get-netneighbor | where IPAddress -eq $gw_IP
ifIndex IPAddress LinkLayerAddress  State       PolicyStore
7       10.0.2.2  52-54-00-12-35-02 Reachable   ActiveStore
```

Firewall Events

Identify the name of the log that contains firewall events. List those events (id 2004) which correspond to holes being made in the firewall.

5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts

The Common Information Model (CIM) instance *Win32_GroupUser* keeps track of which users are in which groups. In the following example, users vagrant and Administrator are Users. The user krbtgt is too, because Domain Users are Users, but we will ignore that for this exercise.

```
GroupComponent                          PartComponent
Win32_Group (Name = "Users", Domain = "DC")   Win32_UserAccount (Name = "vagrant", Domain = "WINDOMAIN")
Win32_Group (Name = "Users", Domain = "DC")   Win32_UserAccount (Name = "Administrator", Domain = "WINDOMAIN")

Win32_Group (Name = "Users", Domain = "DC")   Win32_Group (Name = "Domain Users", Domain = "WINDOMAIN")
Win32_Group (Name = "Domain Users", Domain = "WINDOMAIN") Win32_UserAccount (Name = "krbtgt", Domain = "WINDOMAIN")
```

As a step towards preparing to restrict admin privileges, first check on DC which user accounts belong to an admin group.

Common Information Model

Investigate the Common Information Model to determine the resolution of your display(s).

Advanced: Map NIST PR.AT Awareness and Training with CIS 14 Security Awareness and Training

Provide a mapping between the two frameworks.

CRICOS Provider Code: 00918C | RTO Code: 40939